2025

Comú d'Encamp
ANDORRA

Creació del Comitè i rols de Seguretat de la Informació

COMÚ D'ENCAMP

Control de versió

Control del document

	Nom	Classificació	Data
Fet per:	Awesome S.L.	Normativa	17-10-2023
Aprovat per:	Comitè de seguretat de la informació	Normativa	24-11-2023
Ratificat per:	Junta de Govern	Normativa	24-11-2023

Registre de canvis

Revisió	Versió	Descripció del canvi	Modificat per
Nov-2025	1.1.	Es canvia el format a la plantilla actual de documents del SGSI del Comú. Es canvia la categoria documental (passa de política a normativa).	DSI

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

Índex

1 Capítol 1: antecedents de fet 3
1.1 Primer 3
1.2 Segon 3
1.3 Tercer 3
1.4 Quart 3
1.5 Cinquè 3
2 Capítol 2: fonaments jurídics 3
2.1 Primer 3
2.2 Segon 4
2.3 Tercer 4
2.4 Quart 4
2.5 Cinquè 4
3 Capítol 3: Introducció 4
3.1 Article 1: objecte 4
3.2 Article 2: naturalesa jurídica de l'òrgan 5
3.3 Article 3: Règim jurídic 5
4 Capítol 4: funcions del Comitè de Seguretat de la Informació 5
4.1 Article 1: funcions 5
4.2 Article 2: composició 5
4.3 Article 3 : règim de funcionament i convocatòries del CSI 6
4.4 Article 4 : quòrum 6
4.5 Article 5 : acords del Comitè de Seguretat de la Informació 6
4.6 Article 6 : grups de treball 7
5 Capítol 5: Rols de la seguretat de la informació 7
5.1 Article 1: designació de llocs en Seguretat de la Informació 7
5.2 Article 2: responsable de Tecnologies de la Informació i la Comunicació (RTIC) 7
5.3 Article 3: Delegat de Seguretat de la Informació (DSI) 8
5.4 Article 4: Delegat de Protecció de Dades (DPD) 9
5.5 Article 5: membre del gabinet jurídic 9
6 Disposició addicional primera. Habilitació de desenvolupament 9
7 Disposició final primera. Comunicacions 9

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

1 Capítol 1: antecedents de fet

1.1 Primer

El Comú depèn dels sistemes TIC (Tecnologies de la Informació i Comunicació) aquests sistemes han de ser administrats amb diligència, prenent les mesures adequades per protegir-los davant danys accidentals o deliberats que puguin afectar la disponibilitat, integritat o confidencialitat de la informació tractada o els serveis prestats.

1.2 Segon

Els processos del Comú han d'estar protegits contra amenaces de ràpida evolució amb potencial per incidir en la confidencialitat, integritat, disponibilitat, ús previst i valor de la informació i els serveis.

Per defensar-se d'aquestes amenaces, es requereix una estratègia que s'adapti als canvis en les condicions de l'entorn per garantir la prestació contínua dels serveis. Això implica que els departaments, ciutadans, proveïdors i altres parts que es relacionin amb el Comú han d'aplicar les mesures mínimes de seguretat exigides per aquesta normativa, així com fer un seguiment continu dels nivells de prestació de serveis, seguir i analitzar les vulnerabilitats reportades, i preparar una resposta efectiva als incidents per garantir la continuïtat dels serveis prestats.

1.3 Tercer

Els diferents departaments del Comú s'han de cerciorar que la seguretat TIC és una part integral de cada etapa del cicle de vida del sistema, des de la seva concepció fins a la seva retirada de servei, passant per les decisions de desenvolupament o adquisició i les activitats d'explotació. Els requisits de seguretat i les necessitats de finançament, han d'ésser identificats i inclosos en la planificació, en la sol·licitud d'ofertes, i en plecs de licitació.

1.4 Quart

Els departaments del Comú han d'estar preparats per prevenir, detectar, reaccionar i recuperar-se d'incidents.

1.5 Cinquè

Amb l'aprovació de la Llei 10/2019 del 15 de febrer, de modificació del Codi de l'Administració, del 29 de març de 1989, es dona un impuls definitiu a la implantació dels processos electrònics a les administracions públiques, citant expressament la necessitat de respectar un marc comú de Seguretat de la Informació.

A més, Amb l'entrada en vigor de la llei, consagra la comunicació electrònica entre l'Administració i la ciutadania, fent-se imprescindible garantir el compliment dels principis bàsics i requisits mínims establint les mesures de seguretat necessàries que hauran de ser proporcionals a les dimensions de seguretat rellevants i a la categoria del sistema d'informació a protegir.

2 Capítol 2: fonaments jurídics

2.1 Primer

En el Reglament 418/2022, del 12-10-2022, pel qual s'aprova el Reglament d'infraestructures crítiques del Principat d'Andorra, reiteren en el seu articulat la necessitat de complir amb les mesures de Seguretat de la Informació. Aquest Reglament (en endavant, el "RIC-AD" o "el Reglament") regula l'establiment d'instruments de planificació per mesurar i millorar el nivell

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

de protecció i resiliència de les entitats crítiques i les entitats equivalents a entitats crítiques, de conformitat amb el precepte establert a l'article 11 de la Llei NIS-AD.

2.2 Segon

Així mateix, després de l'entrada en vigor, el dia 25 de maig de 2018, del Reglament (UE) 2016/679 del Parlament Europeu i del Consell, de 27 d'abril de 2016, relatiu a la protecció de les persones físiques pel que fa al tractament de dades personals i a la lliure circulació d'aquestes dades i pel qual es deroga la Directiva 95/46/CE (Reglament general de protecció de dades) i la a Llei 29/2021, del 28 d'octubre, qualificada de protecció de dades personals i garantia de drets digitals (LQPD), en el capítol quart, article 14 de la qual vincula la seguretat de les dades personals al requisits mínims de l´ENS-AD, s' hauran d' adoptar mesures tècniques, organitzatives, així com de protecció legal i compliment, entre les quals es troben la designació de la figura del Delegat de Protecció de Dades.

2.3 Tercer

El principi de seguretat integral i sistemàtica de l´article 8.Sistema de gestió de la seguretat de la informació de l´ENS obliga que la responsabilitat d'iniciar, gestionar i controlar el Sistema de gestió de la seguretat de la informació (SGSI) del Comú recaigui sobre l'òrgan de direcció del Comú, que delega les tasques associades a aquesta responsabilitat en el DSI.

2.4 Quart

Segons l´article 4 de la Llei NIS-AD, de mesures per a la seguretat de les xarxes i dels sistemes d'informació el Marc estratègic de seguretat de les xarxes i dels sistemes d'informació és una estratègia per reforçar la resiliència de les entitats crítiques que inclogui un marc de governança per assolir els objectius estratègics i les prioritats, inclosa una descripció dels rols i les responsabilitats de les autoritats nacionals competents designades en aquesta Llei, entitats crítiques i altres parts implicades en la implementació de l'estratègia.

2.5 Cinquè

Les resolucions, guies, recomanacions i instruccions proporcionades per l'ANC-AD (Agència Nacional de Ciberseguretat d'Andorra) i per l'APDA (Agència Andorrana de Protecció de Dades).

Per l'exposat, es proposa al Comú l'aprovació de la Normativa per la qual es crea el CSI se'n regula la composició i el funcionament i es designen les funcions en Seguretat de la Informació al Comú de d'Encamp.

3 Capítol 3: Introducció

3.1 Article 1: objecte

1.- L'objecte de la present normativa és la constitució d' un òrgan col·legiat amb capacitat decisòria en matèria de Seguretat de la Informació del Comú denominat Comitè de Seguretat de la Informació (CSI), incloent la regulació de les seves composició i funcions.

2.- En la present normativa es designen també les funcions que en matèria de Seguretat de la Informació s' han d'atribuir al Delegat de la Seguretat de la Informació (DSI), al Delegat de Protecció de Dades (DPD), al Responsable de Tecnologies de la Informació i la Comunicació (RTIC) i al Membre del Gabinet Jurídic.

3.- Amb caràcter opcional, altres membres del Comú podran incorporar-se a les tasques del Comitè de Seguretat de la Informació, inclosos grups de treball especialitzats, ja siguin de caràcter intern, extern o mixt.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

4.- El Comitè de Seguretat de la Informació celebrarà les seves sessions amb periodicitat trimestral, prèvia convocatòria a aquest efecte realitzada pel president del Comitè de Seguretat de la Informació.

3.2 Article 2: naturalesa jurídica de l'òrgan

1.- El CSI és un òrgan col·legiat amb capacitat decisòria en la Seguretat de la Informació del Comú, sense personalitat jurídica pròpia.

2.- L'òrgan col·legiat està integrat per les persones designades d'acord als rols establertes en l´article 4 de la Llei NIS-AD, de mesures per a la seguretat de les xarxes i dels sistemes d'informació i a l´article 10.Pla de seguretat del RIC-AD aplicable al Comú.

3.3 Article 3: Règim jurídic

El CSI es regeix per les disposicions de la present normativa, així com per la regulació establerta per a la Llei NIS-AD, de mesures per a la seguretat de les xarxes i dels sistemes d'informació, del RIC- AD, de l´ENS-AD i la Política de Seguretat del Comú i per altres instruccions o criteris interpretatius o altres regulacions que puguin emetre els organismes de control que es relacionin amb la matèria de la Seguretat de la Informació.

4 Capítol 4: funcions del Comitè de Seguretat de la Informació

4.1 Article 1: funcions

Les funcions del CSI són les següents:

- Coordinar els esforços de les diferents àrees en matèria de Seguretat de la Informació, per assegurar que siguin consistents, alineats amb l'estratègia decidida en la matèria, i evitar duplicitats.
- Proposar plans de millora de la Seguretat de la Informació, amb la dotació pressupostària corresponent, i prioritzar les actuacions en matèria de seguretat quan els recursos siguin limitats.
- Vetllar perquè la Seguretat de la Informació es tingui en compte en tots els projectes des de la seva especificació inicial fins a la posada en operació. En particular haurà de vetllar per la creació i utilització de serveis horitzontals que redueixin duplicitats i donin suport a un funcionament homogeni de tots els sistemes TIC.
- Realitzar un seguiment de la gestió dels incidents de seguretat i recomanar possibles actuacions específiques.
- Elaborar i revisar la normativa de Seguretat de la Informació per a la seva aprovació.
- Elaborar i aprovar els requisits de formació i qualificació d'administradors, operadors i usuaris des del punt de vista de Seguretat de la Informació.
- Promoure la realització de les auditories periòdiques ENS-AD i de protecció de dades que permetin verificar el compliment de les obligacions del Comú en matèria de Seguretat de la Informació.

Així mateix, podran ser delegades altres funcions per un altre òrgan del Comú amb competències en la matèria. Les funcions atribuïdes al CSI per un altre òrgan no podran ser delegades si bé podran ser revocades en qualsevol moment.

4.2 Article 2: composició

Els membres que componen el Comitè de Seguretat de la Informació són:

- President: Responsable de Tecnologies de la Informació i la Comunicació (RTIC).

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

- Vicepresident: Delegat de la Seguretat de la Informació (DSI).
- Vocal: Delegat de Protecció de Dades (DPD).
- Vocal: Membre del Gabinet Jurídic.

Així mateix, i amb caràcter opcional, podran incorporar-se a les tasques del CSI grups de treball especialitzats, ja siguin de caràcter intern, extern o mixt.

4.3 Article 3 : règim de funcionament i convocatòries del CSI

Per poder dur a terme les seves obligacions, els membres del CSI es comprometen a participar activament en les reunions i a aportar les seves perspectives per garantir la seguretat i la protecció de les dades del Comú.

El CSI es reunirà trimestralment, o quan existeixen propostes o esdeveniments que ho justifiquin, en les dependències del Comú o bé per videoconferència per tractar els punts corresponents.

Els punts de l'ordre del dia d'una reunió d'un CSI han d´incloure els principals temes següents:

- Lectura i aprovació de l'acta de la reunió anterior: Això permet assegurar que tots els membres del CSI estiguin al corrent dels temes tractats a la reunió anterior i dels acords assolits.
- Seguiment de projectes: El CSI ha de supervisar el progrés dels projectes de Seguretat de la Informació que es duguin a terme al Comú.
- Discussió d'amenaces i vulnerabilitats: El CSI ha de discutir les darreres amenaces i vulnerabilitats a què està exposada el Comú.
- Revisió de mètriques de seguretat: El CSI ha de revisar les mètriques de Seguretat de la Informació per avaluar el rendiment del programa de seguretat del Comú.
- En finalitzar la reunió, el CSI ha de redactar una minuta de sessió que detalli els temes vistos i les decisions preses. Aquesta minuta s'ha d'enviar a tots els membres del CSI i servir com a evidència per demostrar als auditors que el CSI es reuneix periòdicament i aprova les polítiques.

Com punts opcionals, depenent de les circumstàncies es podran incloure ocasionalment altres punts com:

- Plans de resposta a incidents: En el cas que es produeixi un incident de seguretat el CSI es reunirà per avaluar els danys, revisar els plans de resposta a incidents de Seguretat de la Informació del Comú i mitigar l'atac.
- Revisió de resultats d'auditories: El CSI ha de revisar els resultats de les auditories de Seguretat de la Informació per identificar i abordar les vulnerabilitats.

4.4 Article 4 : quòrum

El CSI queda vàlidament constituït amb l'assistència de dos terços dels membres en primera convocatòria i de la meitat dels membres en segona convocatòria.

El CSI també queda vàlidament constituït sense convocatòria prèvia si es reuneixen tots els membres i acorden per unanimitat constituir-se en sessió.

4.5 Article 5 : acords del Comitè de Seguretat de la Informació

Tots els acords del CSI s'han de fer constar per escrit en una acta que ha de signar el president. Qualsevol membre del CSI, de la Junta de Govern o del Consell de Comú té dret a sol·licitar i a obtenir una còpia, total o parcial, de les actes de les reunions del CSI. El president ha de certificar aquestes còpies.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

Els acords del CSI es prenen per majoria simple dels membres. El vot del president és diriment en cas d'empat. Amb caràcter extraordinari, aquelles accions, no havent sigut acordades amb anterioritat, tinguin com a finalitat la protecció dels interessos comunals que es requereixi immediatesa en la presa de decisions, podran ser aprovats per el president o en el seu defecte el vicepresident.

Queda prohibida la delegació de vots al CSI. Qui voti en contra d'un acord determinat pot demanar, a la mateixa reunió on s'ha pres, que el seu vot consti a l'acta.

4.6 Article 6 : grups de treball

Per al desenvolupament de les funcions del CSI es podran constituir grups de treball que desenvoluparan tasques específiques i de temàtica concreta i especialitzada.

La composició dels grups de treball podrà estar integrada per persones empleades del Comú o bé per especialistes externs a aquest, si bé la Presidència de les mateixes recaurà sempre en un membre del CSI.

Les funcions, composició i règim de funcionament es definiran en l'acord de constitució aprovat pel CSI.

5 Capítol 5: Rols de la seguretat de la informació

5.1 Article 1: designació de llocs en Seguretat de la Informació

1.- L'atribució de les funcions de seguretat en els diferents llocs seran realitzades per resolució del CSI.

El Responsable d'Informació serà un lloc de nivell directiu, en ser el responsable últim de la informació comunal, segons es descriu en la Política de Seguretat de la Informació del Comú.

El Delegat de Seguretat de la Informació determina les decisions per satisfer els requisits de seguretat del Comú.

El responsable del Sistema s' estableix a nivell operatiu. Es poden designar Delegats d' aquest responsable segons el que estableix la Política de Seguretat del Comú.

2.- Els rols de seguretat i la descripció dels llocs que els ocuparan són els següents

- President: Responsable de Tecnologies de la Informació i la Comunicació (RTIC).
- Vicepresident: Delegat de la Seguretat de la Informació (DSI).
- Vocal: Delegat de Protecció de Dades (DPD).
- Vocal: Membre del Gabinet Jurídic.

3.- Les competències atribuïdes al lloc s' integraran en la descripció de funcions dels llocs del Comú, si s' escau.

5.2 Article 2: responsable de Tecnologies de la Informació i la Comunicació (RTIC)

El responsable de Sistemes realitzarà les següents funcions:

- Identificació de necessitats de Seguretat de la Informació: El RTIC ha de treballar amb altres departaments per identificar les necessitats de Seguretat de la Informació del Comú. Aquestes necessitats poden variar en funció de la naturalesa de les dades que gestiona el Comú.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

- Planificar i desenvolupar la infraestructura TIC del Comú. Això inclou la planificació de la compra de nous equips i software, la implementació de noves tecnologies la resolució de problemes, la prevenció de caigudes, la supervisió del rendiment dels sistemes i la gestió dels sistemes existents.
- Col·laboració amb altres departaments del Comú: Per garantir la Seguretat de la Informació, aquesta col·laboració ha de ser essencial per a l'èxit de qualsevol programa de Seguretat de la Informació.

Quan la complexitat del sistema ho justifiqui, el Responsable del Sistema podrà proposar per a la designació pel CSI, als responsables del sistema delegats que consideri necessaris, que tindran dependència funcional directa d' aquell i seran responsables en el seu àmbit de totes aquelles accions que els delegui el mateix.

5.3 Article 3: Delegat de Seguretat de la Informació (DSI)

El responsable de Seguretat exercirà les següents funcions:

- Manteniment de sistemes de seguretat: El DSI ha de recopilar i mantenir un inventari de tots els actius d'informació del Comú. Aquest inventari ha de contenir informació sobre la classe de seguretat de cada actiu, la seva ubicació, els seus propietaris i els seus riscos associats.
- Formació i sensibilització al personal sobre la Seguretat Informàtica: Aquesta formació ha de cobrir temes de bones pràctiques com la seguretat de les contrasenyes, l'ús de software segur i la detecció d'atacs entre altres.
- Elaboració i implementació d'una política de Seguretat de la Informació: La política de Seguretat de la Informació defineix els objectius, les mesures i els procediments de seguretat del Comú. El RTIC ha de ser responsable de l'elaboració i implementació d'aquesta política.
- Supervisió del compliment de la política de Seguretat de la Informació: El RTIC ha de supervisar el compliment de la política de Seguretat de la Informació per assegurar-se que es segueix.
- Gestió dels riscos de Seguretat de la Informació: El RTIC ha de realitzar una avaluació de riscos de seguretat per identificar i prioritzar els riscos a què està exposat el Comú. Aquesta avaluació ha de servir per definir i implementar les mesures de seguretat necessàries per mitigar els riscos identificats.
- Gestió de les incidències de seguretat: Això implica investigar la causa de l'incident, identificar les dades compromeses i prendre mesures correctives.
- Gestió de la seguretat dels sistemes: El DSI ha de determinar la categoria de cada sistema, elaborar la declaració d'aplicabilitat i decidir sobre les mesures de seguretat addicionals que s'han d'aplicar. També ha d'aprovar els procediments operatius de seguretat elaborats pel RTIC i verificar l'estat de la seguretat del sistema monitoritzat per el DPD.
- Gestió de la Seguretat de la Informació: El DSI ha de promoure la formació i la conscienciació sobre la Seguretat de la Informació entre els treballadors del Comú. També ha de validar els plans de continuïtat elaborats pel RTIC i rebre els informes sobre el grau d'implantació i eficàcia de les mesures de seguretat físiques.
- Gestió de seguretat dels usuaris: S'encarrega de protegir els sistemes d'informació dels usuaris no autoritzats.
- Determinarà els requisits de Seguretat de la Informació, així com de garantir que es compleixin aquests requisits. També és el responsable de determinar els nivells de Seguretat de la Informació, i de participar en l'acceptació final del risc residual.

El Delegat de Seguretat de la Informació, en funció de la complexitat de l'organització, podrà proposar Delegats de les seves funcions per àrees diferenciades que seran designats pel CSI que tindrà dependència funcional directa i serà responsable en l'àmbit assignat.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

5.4 Article 4: Delegat de Protecció de Dades (DPD)

L'article 39 del RGPD estableix que les funcions del Delegat de Protecció de Dades són les següents:

- Aconsellar i assessorar al Comú sobre les seves obligacions en matèria de protecció de dades.
- Supervisar el compliment de la normativa de protecció de dades.
- Dur a terme auditories de protecció de dades.
- Assistir al Comú en cas de sol·licituds d'accés, rectificació, supressió, oposició i limitació del tractament, així com en cas de vulneració de la seguretat dels sistemes de tractament de dades.
- Gestió i anàlisi de riscos: Identificar els possibles riscos de seguretat del sistema, avaluar-los i prendre mesures per mitigar-los.
- Col·laborar amb les autoritats de control.

5.5 Article 5: membre del gabinet jurídic

Les funcions que fa un membre del gabinet jurídic són les següents:

- Assessorar jurídicament el responsable de la seguretat en l'elaboració i l'aplicació de la política de seguretat, així com en la interpretació i l'aplicació de l'Esquema Nacional de Seguretat (ENS).
- Elaborar i revisar la documentació jurídica relacionada amb la seguretat de la informació, com ara la política de seguretat, els procediments de seguretat i els contractes de seguretat.
- Col·laborar amb el responsable de la seguretat en l'avaluació dels riscos de seguretat i en l'adopció de mesures de seguretat per mitigar-los.
- Representar el responsable de la seguretat davant d'òrgans judicials, administratius o arbitrals en matèria de seguretat de la informació.

6 Disposició addicional primera. Habilitació de desenvolupament

El CSI podrà desenvolupar la present normativa creant i aprovant les normes que siguin necessàries per a assegurar l'objectiu de la Seguretat de la Informació. De forma no limitada, s'hauran d'elaborar les següents normes:

- Normativa de gestió de riscos.
- Normativa d'ús acceptable.
- Normativa de copies de seguretat.
- Normativa de gestió d'actius.
- Normativa de gestió del canvi.

7 Disposició final primera. Comunicacions

La designació d' aquests responsables i les seves funcions serà comunicada a les persones afectades.

Aquesta normativa tindrà efecte des de la seva aprovació.

Per al desenvolupament de la present normativa s'han pres com a referència els requeriments legals previstos en legislacions, com ara el GDPR, la LQPD, NIS-AD, ENS-AD, RIC-AD. Les

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

legislacions i estàndards de seguretat de la informació contemplats a l'abast de la normativa estat detallades al Sistema de Gestió de la Seguretat de la Informació.

Les entitats que en l'àmbit d'una relació laboral o comercial tractin informació titularitat o sota la responsabilitat del Comú exigirà l'adhesió a aquest Sistema de Gestió de la Seguretat de la Informació i reconèixer-ne la responsabilitat de complir i vetllar el compliment dels requisits aplicables en matèria de seguretat de la informació.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.